IS10 Appendix A — Azure Cloud Security Governance Discipline

Security Baseline policy statements and design guidance for the [Company] IIoT Platform on Azure

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

The document outlines the policy statements and design guidance required to support the Security Baseline governance discipline during cloud adoption. Associated risks, tolerance, and remediation strategies are included for reference.

Executive Summary

Cloud deployments face many of the same security risks as workloads hosted in traditional on-premises datacenters. However, one of the primary things that sets cloud security governance apart from traditional security policy is the ease with which resources can be created, potentially adding vulnerabilities if security isn't considered before deployment. This document identifies and determines the business's tolerance for risks, and outlines efforts to remediate these risks. The result is a series of policy statements that should guide the architecture of any solutions deployed to the cloud.

The policies and guidance in this document have been developed in conjunction with the governance best practices documented in the Microsoft Cloud Adoption Framework for Azure (CAF).

Policy Statements

The following statements should guide cloud adoption architecture decisions to ensure compliance with governance efforts related to the Security Baseline discipline.

Asset classification: All deployed assets must be categorized by criticality and data classification. Classifications must be reviewed by the Cloud Governance and Security teams and the application owner before deployment to the cloud.

Network isolation: Network subnets containing protected data must be isolated from any other subnets. Network traffic between protected data subnets must be audited regularly. At a minimum, service-level firewalls must be used to ensure proper isolation. Access to cloud resources should be available only through designed data flows, starting at demilitarized zones (DMZs) protected by a WAF or firewall.

Secure on-premises connectivity: All connections between the on-premises and cloud networks must take place either through a secure encrypted VPN connection or a dedicated private WAN link provided by [Parent Company].

Business Risks

The following security-related business risks have been identified as concerns based on the current plans for cloud adoption.

Risk	Description	Indicators	Resolution
Data breach	Inadvertent exposure or loss of sensitive cloud-hosted data can lead to losing customers, contractual issues, or legal consequences.	Current	Policy statements enforced
Service disruption	Outages and other performance issues due to insecure infrastructure interrupt normal operations and can result in lost productivity or lost business.	Mission-critical workloads deployed	Policy statements drafted but not enforced
Ransomware attack	Combines data theft and service disruption: data is exfiltrated and resources are encrypted, followed by a ransom demand.	Mission-critical workloads deployed	Policy statements deployed
Unauthorized usage of computing resources	Use of [Company]-owned resources to generate income for third parties, for example cryptocurrency mining through injected or deployed malware, generating large costs through resource exhaustion.	Current	Policy statements deployed

Metrics and Indicators

The following are key metrics and indicators that will guide the resolution or mitigation of business risks. For additional examples of relevant metrics or indicators, see the governance theory section of CAF.

Metrics

Current security management efforts aim to govern or improve the following key metrics.

- **Data classification:** Number of cloud-stored data sets and services that are unclassified according to the organization's privacy, compliance, or business impact standards.
- **Attack surface:** Total number of data sources, services, and applications that are cloud-hosted and accessible over the internet.
- **Number of sensitive data stores**: Number of storage endpoints or databases that contain sensitive data and should be protected.
- **Malware protection:** Percentage of deployed virtual machines (VMs) that have all required antimalware, firewall, or other security software installed.
- **Patch latency:** Time since VMs last had OS and software patches applied.
- **Security health recommendations:** Number of security recommendations for bringing deployed resources up to health standards, organized by severity.
- **Number of unencrypted data stores:** Number of sensitive data stores that are not encrypted.
- **Number of unmonitored services:** Number of services that are deployed but not monitored.
- **Overall Standards Compliance:** Ratio of resources adhering to security standards.

Indicators

The following indicators will trigger changes in policy statements based on changes in metrics and other conditions.

- **Current:** Current state of metrics. Any policy statements listed as current should be actively enforced.
- **Patching trigger: Deployed virtual machines or services where OS or software patches have not been applied in the last 60 days.**
- **Mission-critical workloads trigger:** Deploying mission-critical workloads to the cloud will require creation and enforcement of policy statements to remediate risks related to service disruption.
- **Protected data trigger:** Hosting data on the cloud that can be classified as confidential, private, or otherwise subject to regulatory concerns will require policies in place to prevent the risk of data breach.
- **Standards compliance trigger:** A company with more than 80% of resources out of security standards compliance should invest in the Security Baseline discipline to ensure standards are applied consistently across IT infrastructure.

Policy compliance processes

The following section outlines the processes that will ensure cloud deployments remain in compliance with Security Baseline policies. This includes an overview of the planning, review and reporting processes performed by the Cloud Governance team and Security team, as well as the ongoing monitoring and enforcement processes that can be automated or supplemented with tooling, such as a SIEM, to allow faster response to policy deviations.

Planning, review, and reporting processes

Initial risk assessment and planning:

As part of the initial adoption of the Security Baseline discipline, the Cloud Governance and Security team will identify core business risks and tolerances related to cloud security. The team will use this information to begin discussions on specific technical risks with IT and security staff, and to develop a baseline set of security policies as part of developing an initial governance strategy.

Deployment planning:

Before deploying any workload or asset, the IT and Cloud Governance teams will perform a security review with the Security team to identify any new risks and ensure all access and data security policy requirements are met.

Deployment testing:

As part of the deployment process for any workload or asset, the Cloud Governance team, in cooperation with the Security team, will review the deployment to validate security policy compliance.

Annual planning:

On an annual basis, the Cloud Governance team, together with the Security team, will perform a high-level review of security strategy. Future corporate priorities and updated cloud adoption strategies will be explored to identify potential risk increase or other emerging security needs. This process will also involve a review of the latest security best practices and their integration into policies and review processes.

Quarterly review and planning:

On a quarterly basis, the Cloud Governance team, together with the Security team, will review security audit data and incident reports to identify any changes required in security policy. As part of this process, the current cybersecurity landscape will be explored to proactively anticipate emerging threats and update policy as appropriate. After the review is complete, design guidance will be aligned with updated policy.

This review will also evaluate the Cloud Governance team's current membership for knowledge gaps related to new or evolving policy and risks related to security. The team will invite relevant security and IT staff to participate in reviews and planning as either temporary technical advisors or permanent members of the team.

Education and Training:

On a bi-weekly basis, the Security team will offer training sessions to ensure IT staff and developers are up-to-date on the latest security policy requirements. As part of this process, the team will review all documentation, guidance, or other training assets and update them to ensure they are in sync with the latest corporate policy statements.

Monthly audit and reporting reviews:

On a monthly basis, the Cloud Governance and Security teams will audit all cloud deployments to ensure their continued alignment with security policy. Security-related activities will be reviewed with IT staff and the team will identify any compliance issues not already handled as part of the ongoing

monitoring and enforcement process. This process will result in a report for the Cloud Strategy team and each cloud adoption team to communicate overall adherence to policy. The report is also stored for auditing and legal purposes.

Ongoing monitoring

Security and IT teams will implement automated monitoring systems for the organization's cloud infrastructure, capturing relevant log data needed to evaluate security-related risks. They will also establish reporting and alerting systems to ensure prompt detection and mitigation of potential security policy violations.

Violation Triggers and Enforcement Actions

Increase in attacks detected:

If any resource experiences a 25% increase in brute force or DDoS attacks, discuss with IT security staff and the workload owner to determine remedies. Track the issue and update guidance if policy revision is necessary to prevent future incidents.

Unclassified data detected:

Any data source without an appropriate privacy, security, or business impact classification will have external access denied until the classification is applied by the data owner and the appropriate level of data protection applied.

Network vulnerability detected:

Access to any resource not explicitly allowed by the network access policies should trigger an alert to Security staff and the relevant workload owner. Track the issue and update guidance if policy revision is necessary to mitigate future incidents.

Toolchain

The following cloud provider specific tools will be implemented to automate the policy statements in this document.

Azure Specific Tooling

- **Access control to resources and resource creation (RBAC):** Microsoft Entra ID (formerly Azure Active Directory), Azure RBAC
- **Infrastructure as code and deployment automation:** Azure Bicep, deployment through GitHub Actions
- **Network and service isolation:** Azure Resource Manager, network security groups (NSGs), service firewalls, Web Application Firewall
- **Detection of malicious activity (SIEM):** Azure Monitor, Microsoft Sentinel
- **Preemptive vulnerability detection:** Microsoft Defender for Cloud (formerly Azure Security Center)